

- **Expediente N.º: EXP202313747**

RESOLUCIÓN DE TERMINACIÓN DEL PROCEDIMIENTO POR RECONOCIMIENTO DE RESPONSABILIDAD Y PAGO VOLUNTARIO

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: Con fecha 27 de marzo de 2025, la Presidencia de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a **A.A.A.** (en adelante, **A.A.A.**), mediante el acuerdo que se transcribe:

<<

Expediente N.º: EXP202313747

ACUERDO DE INICIO DE PROCEDIMIENTO SANCIONADOR

De las actuaciones practicadas por la Agencia Española de Protección de Datos y en base a los siguientes

HECHOS

PRIMERO: La Agencia Española de Protección de Datos ha tenido conocimiento de ciertos hechos que podrían constituir una posible infracción imputable a **A.A.A.**, con NIF *****NIF.1** (en adelante, parte denunciada o **A.A.A.**).

Los hechos que se ponen en conocimiento de esta autoridad:

La parte denunciada es titular de una oficina de farmacia, sita en *****LOCALIDAD.1**, en la que se está llevando a cabo una recopilación de los datos personales, incluidos datos relativos a la salud, de muchos de los pacientes que acuden a ella, realizada cuando el paciente desea que se le renueve la medicación que tiene introducida en la tarjeta sanitaria del Sistema de Salud de la Comunidad de Castilla y León (Sacyl). Para ello, según la persona denunciante, se pasa la tarjeta por el lector teniendo abierto un archivo "Excel", (...), anotando y almacenando en aquel archivo la medicación que el paciente desea renovar junto a sus datos personales, *"sin garantías de protección ni consentimiento informado"*.

Se indica que la oficina de farmacia dispone de varios ordenadores ubicados en dos mostradores del establecimiento, en cuyos escritorios pueden localizarse estos archivos "Excel" con los nombres "(...)".

Se añade que *"También se está retirando medicación sin la tarjeta física del sistema sanitario de Castilla y León (Sacyl) y sin que el paciente esté físicamente presente en*

la oficina de farmacia. (...) donde corta la información extraída de la banda magnética de la tarjeta sanitaria sin consentimiento informado para acceder a los datos de medicación y de salud del paciente en cuestión”.

Se aportan los ficheros mencionados en la denuncia, (...).

Del examen de estos documentos resulta lo siguiente:

. El primero de los archivos incluye tres hojas:

. Hoja 1: con anotaciones de fechas comprendidas entre el 18/01/2018 y el 22/03/2023 y 1746 grupos con datos personales relativos a Código de identificación personal autonómico del paciente (CIPA), Código de identificación del paciente en el Sistema Nacional de Salud (CIP), nombre y apellidos de paciente, nombre del centro de salud, nombre y apellido del médico e indicaciones para el médico (incluye la palabra “medicación”, o nombres de medicamentos, antecedidos por la indicación “renovar” en 1.444 de los casos).

. Hoja 2: con anotaciones de fechas comprendidas entre 18/01/2020 y 31/12/2021 y 13.050 grupos con datos personales relativos a CIPA, CIP y nombre y apellidos de paciente.

. Hoja 4: 5 grupos con datos similares a los recogidos en la Hoja 2

. El primero de los archivos incluye tres hojas:

. Hoja 1: anotaciones de fechas comprendidas entre 05/10/2018 y 08/03/2023 y 1.179 grupos con datos similares a los recogidos en la Hoja 1 del archivo anterior (con la indicación “renovar” en 912 de los casos).

. Hoja 2: con anotaciones de fechas comprendidas entre 25/01/2020 y 03/02/2023 y 10.038 grupos con datos personales relativos a CIPA, CIP y nombre y apellidos de paciente.

. “test de antígenos”: 7 grupos con datos relativos a nombre o nombre y apellido y número de teléfono móvil.

SEGUNDO: Como consecuencia de los hechos conocidos y su relevancia, con fecha 06/10/2023, la Directora de la Agencia Española de Protección de Datos instó a la Subdirección General de Inspección de Datos (SGID) a iniciar las actuaciones previas de investigación a las que se refiere el artículo 67 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD).

TERCERO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VIII, de la LOPDGDD.

1. Se cursó una solicitud de información a la persona denunciante para que aportara fotografías que muestren la situación de los ordenadores, fotografías o copias de los escritorios de los ordenadores en los que aparecen los iconos de los mencionados

archivos, o de la ruta al directorio en el que se encuentran, y fotografías o secuencia del proceso de copia de los datos a las hojas de cálculo.

Se recibe respuesta, de fecha 09/12/2023, con la que aporta imágenes mostrando la ubicación de los ordenadores sobre los mostradores de venta al público, e imágenes de una de las hojas “Excel” a las que se refiere la denuncia. En este escrito de respuesta manifiesta que al *“pasar la tarjeta con el programa Excel abierto, la información se guarda en una celda del programa y acto seguido se corta y pega esa información (...). Con esta información se retira medicación sin estar presente el titular de la tarjeta”*.

2. Con fecha 19/02/2024 se realizó una inspección presencial en la oficina de farmacia denunciada.

En este acto, según consta en acta de inspección, los Servicios de Inspección de la AEPD accedieron a los ordenadores de la oficina de farmacia, encontrando los siguientes ficheros, de los que la parte denunciada facilitó copia:

- . (...).
- . (...).
- . (...).

En Acta de inspección consta que en estos ficheros existen datos desde el día 04/10/2023 hasta el 05/02/2024.

Por otra parte, según consta en el informe de actuaciones elaborado por aquellos Servicios, los tipos de datos encontrados en estos archivos coinciden con los encontrados en los documentos aportados con la denuncia:

- Fecha
- Código de identificación personal autonómico del paciente (CIPA).
- Código de identificación del paciente en el Sistema Nacional de Salud (CIP).
- Nombre y apellidos de paciente.
- Nombre del centro de salud.
- Nombre y apellido del médico.
- Indicaciones para el médico (en la mayoría de los casos: “renovar”, seguido de “medicación” o de nombres de medicamentos o productos sanitarios).
- En de los documentos aportados con la denuncia aparecen números de teléfono.
- Notación de haber sido enviado

Examinados los documentos, se comprueba que incluyen la información siguiente:

. (...). Contiene 3 grupos con datos relativos a CIPA, CIP, nombre y apellidos de paciente, centro de salud, nombre y apellido del médico (en 1 grupo) e indicaciones para el médico (en 1 caso se indica “renovar hierro”).

. (...). Contiene dos hojas “Excel”: la primera de ellas con 50 grupos de datos con anotaciones comprendidas entre las fechas 04/10/2023 y 05/02/2024 y los mismos datos del archivo anterior; la segunda contiene 819 grupos de datos con anotaciones de fechas comprendidas 28/11/2023 y 27/12/2023 y los

datos relativos a CIPA, CIP y nombre y apellidos de paciente.

. (...). También con dos hojas “Excel”: una de ellas con 11 grupos de datos con anotaciones comprendidas entre las fechas 26/10/2023 y 29/01/2024 y los mismos datos recogidos en la primera hoja de los archivos anteriores; la otra contiene 58 grupos de datos con anotaciones todas ellas de fecha 28/11/2023 y datos relativos a CIPA, CIP y nombre y apellidos de paciente.

Asimismo, consta en Acta de Inspección que, después de ser informada de que la visita de inspección está relacionada con el almacenamiento en los ordenadores de la oficina de datos personales de clientes extraídos del sistema (...), la persona titular de la oficina de farmacia realizó las manifestaciones siguientes:

“ Finalidad: facilitar la renovación del medicamento sin que el paciente tenga que acudir al centro de salud. Para ello, envían un correo electrónico al centro de salud con los datos del paciente, el médico que realizó la prescripción y el medicamento.

Adicionalmente el inspeccionado manifiesta que emplea los datos registrados para poder acceder al módulo de receta electrónica y registrar la venta en el sistema de receta electrónica sin que el paciente esté presente en la farmacia, en caso de error en la comunicación, tiempo excedido, error en el ordenador, etc.

. Información proporcionada a los clientes sobre este tratamiento: no se proporciona información específica a los clientes sobre este tratamiento. No obstante, el inspeccionado manifiesta que el cliente tiene acceso visual en todo momento a la pantalla del ordenador para ver lo que se está haciendo.

. Personal con acceso a los ordenadores que contienen los ficheros y si estos están protegidos mediante contraseña: el inspeccionado manifiesta que en el momento de la inspección, además de él mismo, tienen permiso de acceso las tres personas empleadas en la farmacia. (...).

Solicitada información al inspeccionado acerca de si estos archivos se almacenan en algún otro lugar a modo de copia de seguridad o con cualquier otro fin y, en este caso, tiempo de conservación de estos ficheros: el inspeccionado contesta que estos ficheros no se copian ni almacenan en ningún otro sitio.

. Preguntado al inspeccionado cuál es el procedimiento empleado para trasladar los datos personales de los clientes a los ficheros Excel, manifiesta que los datos de la tarjeta sanitaria pasan al fichero Excel de forma automática al pasar la tarjeta por el lector magnético y el resto de datos se incorporan de forma manual (los datos de medicamentos se extraen (...)) y los del médico y centro de salud a partir de los que aparecen impresos en la tarjeta sanitaria)”.

3. Ante los indicios de tratamientos irregulares de datos personales en centros de salud de Castilla y León, con fecha 27/02/2024, se realizó un requerimiento de información a las Gerencia Regional de Salud en relación con el tratamiento de datos personales llevado a cabo para la renovación de prescripciones.

Como respuesta a dicho requerimiento, se recibieron escritos de la DPD de SACYL, los días 1 de abril, 15 de abril, 19 de abril y 24 de mayo, de 2024.

A) La respuesta de 01/04/2024 consistió en la aportación, entre otros, de los documentos siguientes:

a) *“Procedimiento de comunicación directa entre las oficinas de farmacia y médicos/enfermeras de los centros de salud”* (incluye en su parte superior los logos de “Sacyl” y “Atención Primaria Valladolid Oeste”).

Se presenta el documento expresando la necesidad de que las oficinas de farmacia colaboren en la detección de errores y en optimizar la eficacia en las dispensaciones de medicamentos y la seguridad de los pacientes. Seguidamente se indica:

“En 2016 se inició un sistema de comunicación entre médicos y oficinas de farmacia en colaboración con el Colegio de Farmacéuticos de Valladolid para la resolución directa de incidencias en Receta Electrónica (RE) mediante el envío por correo electrónico de una plantilla que se ha ido extendiendo a los centros urbanos y semiurbanos del área”.

El objetivo es que la incidencia se resuelva *“sin que el paciente acuda a consulta, para evitar malentendidos, y desplazamientos innecesarios del paciente, reducir el tiempo dedicado por el médico a la resolución de este tipo de incidencias y para favorecer la colaboración de los farmacéuticos comunitarios en la detección de errores en la medicación”.*

Se describen las incidencias que se pueden resolver por esta vía:

- . Ventana de dispensación cerrada: válido para dispensación interrumpida en la farmacia cuando el paciente no retira el medicamento en los períodos que se indican. *“No válido para renovaciones de tratamiento, el paciente debe acudir a consulta”.*
- . Error o dudas de posología.
- . Tratamiento activo que el paciente no utiliza Ayuda a detectar tratamientos que el paciente no necesita o errores de duración.
- . Otros.

Se advierte que *“este procedimiento no es válido para renovaciones ni para recuperar tratamientos cerrados ya que el paciente debe acudir a consulta para su valoración individual, por lo tanto, en estos casos no se realizará ninguna acción y la oficina de farmacia derivará al paciente al centro de salud”.*

Seguidamente se describe el procedimiento a seguir:

“El farmacéutico cumplimenta el impreso “Comunicación e incidencias detectadas en farmacias con receta electrónica” y lo envía por correo electrónico al buzón de gestión del centro de salud al que corresponda el paciente...”

El responsable de... de cada centro de salud traslada la comunicación de

incidencia al médico o enfermera del paciente en función del tipo de incidencia comunicada...

El médico o enfermera valora la incidencia y, si procede, la resuelve...

Cada centro de salud determinará la forma de gestionar estas incidencias (creación de una consulta no presencial, resolución al final de consulta, etc.).

Al detallar el procedimiento se indica a los facultativos que “no se deben realizar renovaciones de tratamientos sin ver al paciente ni recuperar tratamientos cerrados”.

b) Comunicación que el Colegio Oficial de Farmacéuticos de Valladolid dirigió a sus colegiados sobre el procedimiento de comunicación directa descrito en el subapartado a) anterior (con el nombre de archivo “*protocolo incidencias RE mail feb20 (1).pdf*”):

“La información contenida en este documento es de uso exclusivo para los colegiados del Colegio Oficial de Farmacéuticos de Valladolid a los únicos efectos de comunicar incidencias detectadas en farmacia con receta electrónica.

Te informamos que, en las siguientes Zona Básicas de Salud de la capital y provincia está operativo un protocolo de comunicación de incidencias de receta electrónica y aunque tu Centro de Salud no esté aún incluido, puedes notificar incidencias correspondientes a pacientes pertenecientes a dichos Centro.

Se trata de enviar la plantilla cumplimentada mediante correo electrónico con la incidencia detectada:

Ventana de dispensación cerrada

Error de posología

Tratamiento activo que el paciente no utiliza

Falta de firma

Otras

En 48 horas el médico, si lo estima oportuno, resolverá la incidencia sin necesidad de que el paciente vuelva a consulta”.

Seguidamente se indican los correos electrónicos a los que hay que enviar la plantilla (20 direcciones de centros de salud de la ciudad de Valladolid y dos de la provincia).

c) “Comunicación de incidencias detectadas en farmacias con receta electrónica” (con el nombre de archivo “*Plantilla incidencias receta electrónica mayo19 (5).docx*”). Incluye campos para reseñar la información siguiente:

- . Farmacia
- . Centro de Salud
- . Médico prescriptor
- . CIP/CIPA del paciente
- . Incidencia detectada (se pueden marcar las opciones: Ventana de dispensación cerrada; Error de posología; Tratamiento activo que el paciente no utiliza; Otras)
- . Medicamentos afectados

. Datos de contacto de la farmacia (teléfono y dirección de correo electrónico)

d) Se aportan diversos correos electrónicos remitidos por la oficina de farmacia denunciada a distintos centros de salud adjuntando el formulario anterior cumplimentado. En el “asunto” de estos correos se indica “Renovar receta electrónica”, “Incidencia receta electrónica” o “Renovar medicación”.

B) La respuesta de 15/04/2024 consistió en la aportación de los documentos siguientes:

a) Informe de Sacyl sobre el procedimiento de comunicación al que se refiere el apartado A) anterior (este documento fue remitido nuevamente con la respuesta de 25/05/2024).

En este informe se hace referencia a la implantación de la receta electrónica a lo largo de los años 2015 y 2016 y a las dificultades puntuales que se detectaban en las oficinas de farmacia, indicando que ello llevó a algunas áreas de Sacyl, como las de Valladolid Este y Valladolid Oeste, a establecer un procedimiento de comunicación ágil entre las oficinas de farmacia y los centros de salud, el cual ha resuelto incidencias y tenido una aceptación adecuada por parte de los profesionales y pacientes.

Añade que, a partir del requerimiento de la AEPD, se han identificado aspectos que *“no están acordes a la LOPDGDD”*, por lo que se ha valorado con las dos Gerencias de Atención Primaria revisar el circuito de comunicación, de forma que se dé respuesta a las necesidades y se respete el tratamiento de los datos personales de los usuarios, y revisar también *“la motivación de las comunicaciones realizadas a través de este circuito para limitar su utilización a las causas y motivos definidos inicialmente en el procedimiento”*.

b) Respuesta de la Gerencia de Atención Primaria Valladolid Este, de fecha 11/04/2024:

Los correos electrónicos se envían a la dirección “(...)@...”, creado en cada centro de salud para comunicación, instrucciones, mensajes, intercambio de documentación.

Reitera los motivos que llevaron a diseñar, junto con el Colegio Oficial de Farmacéuticos de Valladolid, el indicado procedimiento de comunicación entre farmacéuticos y médicos de familia, con el propósito de resolver incidencias que no permitían la dispensación, pero tampoco requerían una consulta presencial con el facultativo.

C) La respuesta de 19/04/2024 acompaña un informe de la Gerencia de Atención Primaria de Valladolid Oeste.

En este documento se explican nuevamente las razones y el propósito que llevó a establecer aquel procedimiento en el año 2017, acordado por las Gerencias de Atención Primaria de Valladolid (Este y Oeste) y el Colegio Oficial de Farmacéuticos de la provincia, destacando que era muy efectivo para gestionar

algunas incidencias como la dispensación interrumpida, no siendo válido para solicitar renovación de tratamientos.

Hace referencia al formulario empleado para comunicar las incidencias, ya detallado, y a las personas que acceden a los correos y forma de acceso.

Señala que el procedimiento estaba generalizado en la mayor parte de farmacias de Valladolid capital y un municipio.

Con sus respuestas anteriores, las Gerencias de Atención Primaria Valladolid Este y Oeste remitieron a esta AEPD 173 correos remitidos entre la farmacia investigada y los centros de salud, durante el período 05/10/2023 y 18/03/2024. En los correos aparece como remitente o como correo de contacto “*****EMAIL.1**”, y se indican datos en los apartados “Médico prescriptor” y “CIP/CIPA del paciente”; como incidencia detectada se indica “Ventana de dispensación cerrada” y en el apartado “Medicamentos afectados” se indica “renovar” seguido de la palabra “medicación” (en 54 correos) o del nombre de medicamentos o productos sanitarios (en 111 correos).

4. Con fecha 29/10/2024, se realizó un nuevo requerimiento de información a la Consejería de Sanidad de Castilla y León.

En respuesta a esta solicitud de información se recibió informe elaborado por el Servicio de Información y de Prestación Farmacéutica en Atención Primaria, de fecha 15/11/2024. En relación con el procedimiento de comunicación directa mediante correos electrónicos y con los usos realizados (los tres usos previstos inicialmente y la renovación de las prescripciones a los pacientes), el Servicio informante indica que, tras el requerimiento de información de la AEPD de 27/02/2024, las Gerencias de AP de Valladolid Este y Oeste revisaron su finalidad y motivación, se valoraron las alternativas disponibles y se identificaron las actuaciones objeto de modificación para el cumplimiento de la protección de datos, decidiéndose finalizar la vigencia del procedimiento de comunicación.

Dicha decisión se trasladó a la Gerencia de Salud de las Áreas de Valladolid y al Colegio de Farmacéuticos de Valladolid el 21 de mayo de 2024. Por tanto, en la actualidad ya no está vigente la vía de comunicación objeto de requerimiento de información por parte de la AEPD para ninguno de los usos.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para iniciar y resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

II Procedimiento

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos”.*

De acuerdo con el artículo 64 de la LOPDGDD, y teniendo en cuenta las características de las presuntas infracciones cometidas, se inicia un procedimiento sancionador.

El procedimiento tendrá una duración máxima de doce meses a contar desde la fecha del acuerdo de inicio. Transcurrido ese plazo se producirá su caducidad y, en consecuencia, el archivo de actuaciones, de conformidad con lo establecido en el artículo 64 de la LOPDGDD.

Si en el plazo estipulado no efectuara alegaciones a este acuerdo de inicio, el mismo podrá ser considerado propuesta de resolución, según lo establecido en el artículo 64.2.f) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP).

III Cuestiones previas

El artículo 4.1) del RGPD, define «dato personal» como: “toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona”.

El artículo 4.2) del RGPD, define «tratamiento» como: “cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción.”

El artículo 4.7) del RGPD, define al «responsable del tratamiento» o «responsable» como: “la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros”. A su vez el artículo 4.8) del RGPD determina al «encargado del tratamiento» o «encargado» como la persona física o jurídica, autoridad pública, servicio u otro organismo que trate datos personales por cuenta del responsable del tratamiento.

En el presente caso, de acuerdo con lo establecido en el artículo 4.1 y 4.2 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que **A.A.A.** realiza, entre otros tratamientos, la recogida, registro, conservación, consulta o uso de datos personales de personas físicas relativos a nombre y apellido, número de teléfono, códigos de identificación personal, además de datos de salud (tratamientos médicos), nombre del facultativo médico que les asiste y centro de salud de atención primaria al que pertenecen.

A.A.A. realiza esta actividad en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD.

Resulta preciso resaltar la especial cualidad de los datos personales que son objeto de tratamiento, pues ofrecen información acerca de la salud de las personas. Así, el RGPD establece un concepto muy amplio de los datos de salud y les otorga un régimen específico, el correspondiente a las denominadas “*categorías especiales de datos*” reguladas en el artículo 9 del texto normativo.

Se consideran datos de salud, según el artículo 4.15 del RGPD, aquellos “*datos personales relativos a la salud física o mental de una persona física, incluida la prestación de servicios de atención sanitaria, que revelen información sobre su estado de salud*”.

Sobre el dato de salud señala el considerando 35 del RGPD:

“Entre los datos personales relativos a la salud se deben incluir todos los datos relativos al estado de salud del interesado que dan información sobre su estado de salud física o mental pasado, presente o futuro. Se incluye la información sobre la persona física recogida con ocasión de su inscripción a efectos de asistencia sanitaria, o con ocasión de la prestación de tal asistencia, de conformidad con la Directiva 2011/24/UE del Parlamento Europeo y del Consejo; todo número, símbolo o dato asignado a una persona física que la identifique de manera unívoca a efectos sanitarios; la información obtenida de pruebas o exámenes de una parte del cuerpo o de una sustancia corporal, incluida la procedente de datos genéticos y muestras biológicas, y cualquier información relativa, a título de ejemplo, a una enfermedad, una discapacidad, el riesgo de padecer enfermedades, el historial médico, el tratamiento clínico o el estado fisiológico o biomédico del interesado, independientemente de su fuente, por ejemplo un médico u otro profesional sanitario, un hospital, un dispositivo médico, o una prueba diagnóstica in vitro.”

Las “*categorías especiales de datos*”, considerando que por su naturaleza especialmente sensible incorporan un riesgo mayor, se someten a un estándar de protección más elevado, estableciéndose en el citado artículo 9.1 del RGPD el principio de prohibición de tratamiento, salvo que concurra alguna de las circunstancias previstas en su apartado 2.

El considerando 51 dispone, sobre las categorías especiales de datos personales lo siguiente:

“Especial protección merecen los datos personales que, por su naturaleza, son particularmente sensibles en relación con los derechos y las libertades fundamentales, ya que el contexto de su tratamiento podría entrañar importantes riesgos para los derechos y las libertades fundamentales. [...] Tales datos personales no deben ser tratados, a menos que se permita su tratamiento en situaciones específicas contempladas en el presente Reglamento, habida cuenta de que los Estados miembros pueden establecer disposiciones específicas sobre protección de datos con objeto de adaptar la aplicación de las normas del presente Reglamento al cumplimiento de una obligación legal o al cumplimiento de una misión realizada en interés público o en el ejercicio de poderes públicos conferidos al responsable del tratamiento. Además de los requisitos específicos de ese tratamiento, deben aplicarse los principios generales y otras normas del presente Reglamento, sobre todo en lo que se refiere a las condiciones de licitud del tratamiento. Se deben establecer de forma explícita excepciones a la prohibición general de tratamiento de esas categorías especiales de datos personales, entre otras cosas cuando el interesado dé su consentimiento explícito o tratándose de necesidades específicas, en particular cuando el tratamiento sea realizado en el marco de actividades legítimas por determinadas asociaciones o fundaciones cuyo objetivo sea permitir el ejercicio de las libertades fundamentales”.

IV

Síntesis de los hechos

A raíz de una denuncia formulada contra **A.A.A.** y de las primeras comprobaciones realizadas, esta AEPD tuvo conocimiento de la recogida de datos de clientes para remitir un correo electrónico, dirigido al centro de salud respectivo, con la finalidad de que la medicación prescrita pudiera renovarse sin que el paciente acudiese al centro.

Se consultó al respecto a la Consejería de Sanidad de Castilla y León y a la Gerencia Regional de Salud.

Estas entidades informaron que, tras la implantación del sistema de Receta Electrónica en 2015/2016, se identificaron algunas dificultades en la obtención de medicamentos por parte de los pacientes, motivando que las Gerencias de Atención Primaria de Valladolid Este y Oeste, en 2017, implantaran un procedimiento que permitiera a las oficinas de farmacia comunicar a los profesionales de los centros de salud posibles incidencias asociadas a la prescripción de medicamentos.

Dicho procedimiento, que fue requerido a las oficinas de farmacia con la colaboración del Colegio Oficial de Farmacéuticos de Valladolid, contemplaba la comunicación entre estas oficinas de farmacia y los centros de salud a través de correo electrónico. La oficina de farmacia debía cumplimentar y remitir un formulario, siempre mediante correo electrónico dirigido a un buzón de gestión dispuesto en cada centro, para que fuera trasladado al médico o enfermera del paciente en función del tipo de incidencia.

Ese formulario se diseñó para que fuera cumplimentado con los datos de la farmacia, nombre del centro de salud, médico prescriptor, CIP/CIPA del paciente, tipo de incidencia, medicamentos afectados y datos de contacto de la farmacia (número de teléfono y dirección de correo electrónico). Se describen las incidencias que se pueden resolver por esta vía (“Ventana de dispensación cerrada” -cuando el paciente no retira

el medicamento-, “Error o dudas de posología”, “Tratamiento activo que el paciente no utiliza” y “Otros”) y se advierte que este procedimiento no es válido para renovaciones ni para tratamientos cerrados. No obstante, aunque se trataba de un uso no previsto inicialmente, este sistema de comunicación se utilizó también para la renovación de medicamentos.

El procedimiento dispuesto para las Áreas de Valladolid no fue abandonado hasta el 21/05/2024, una vez conocidos los requerimientos de información cursados por los Servicios de Inspección de esta AEPD.

La documentación recabada por los Servicios de Inspección incluye 173 correos enviados por **A.A.A.** a centros de salud, la mayor parte de los cuales comunica como incidencia la renovación de medicación.

Se comprueba, por otra parte, que los datos utilizados para realizar aquellas comunicaciones a los centros de salud fueron recopilados por **A.A.A.** en una base de datos personales propia, al margen del sistema de receta electrónica del sistema de Castilla y León, integrada por los ficheros en formato “Excel” que se detallan en el antecedente Tercero. En estos archivos “Excel”, **A.A.A.** anota y conserva la información contenida en los formularios remitidos a los centros de salud (nombre del centro de salud, nombre y apellidos del médico prescriptor, CIP/CIPA del paciente, tipo de incidencia o circunstancias apreciadas por el farmacéutico respecto del tratamiento médico, medicamentos afectados), a los que añadía los datos personales relativos a nombre, apellidos del paciente/cliente, además de una notación sobre el envío del correo electrónico.

Para el registro de estos datos en sus ficheros, **A.A.A.** dispuso un procedimiento automatizado que permitía la recogida de la información al pasar la tarjeta sanitaria del paciente por el lector magnético, incorporando de forma manual el medicamento y los datos del médico y centro de salud, que aparecen impresos en la tarjeta sanitaria.

La investigación realizada ha permitido constatar que los datos personales registrados se utilizan por **A.A.A.** para otras finalidades propias, concretamente para poder registrar la dispensación del medicamento en el módulo de receta electrónica del sistema sanitario de Castilla y León sin que el paciente se encuentre presente en la oficina de farmacia, *“en caso de error en la comunicación, tiempo excedido, error en el ordenador, etc.”*.

Los repetidos archivos se encuentran alojados en el “escritorio” de los ordenadores empleados en la oficina de farmacia y estos ubicados en los mostradores de venta al público, sin que el responsable haya previsto la realización copias de seguridad ni su almacenamiento en otro lugar. A ellos pueden acceder **A.A.A.** y todos los empleados del establecimiento (tres personas en el momento de la inspección realizada), solo con la contraseña que protege el ordenador, conocida por todos.

Finalmente, en relación con los hechos expuestos, **A.A.A.** manifestó a los servicios de inspección de esta AEPD que no proporciona a sus clientes información alguna en materia de protección de datos respecto de los tratamientos descritos, añadiendo que el cliente *“tiene acceso visual en todo momento a la pantalla del ordenador para ver lo que se está haciendo”*.

Considerando cuanto antecede, se considera que existen indicios de una posible vulneración por parte de **A.A.A.** de lo establecido en los artículos 13, 9 y 32 del RGPD, con el alcance que se expresa en los Fundamentos de Derecho que siguen.

V

Obligación incumplida: Infracción del artículo 13 del RGPD

Considerando los tratamientos de datos personales realizados, **A.A.A.** viene obligado a dar cumplimiento al principio de transparencia establecido en el artículo 5.1 del RGPD, según el cual los datos personales serán *“tratados de manera lícita, leal y transparente en relación con el interesado (licitud, lealtad y transparencia)”*; y desarrollado en el Capítulo III, Sección 1ª, del mismo Reglamento (artículos 12 y siguientes).

El artículo 12.1 del RGPD establece la obligación del responsable del tratamiento de tomar las medidas oportunas para *“facilitar al interesado toda información indicada en los artículos 13 y 14, así como cualquier comunicación con arreglo a los artículos 15 a 22 y 34 relativa al tratamiento, en forma concisa, transparente, inteligible y de fácil acceso, con un lenguaje claro y sencillo, en particular cualquier información dirigida a un niño”*.

Cuando los datos personales se recaben directamente del interesado, la información deberá facilitarse en el momento mismo en que tiene lugar esa recogida de datos. El artículo 13 del RGPD detalla esa información en los términos siguientes:

“1. Cuando se obtengan de un interesado datos personales relativos a él, el responsable del tratamiento, en el momento en que estos se obtengan, le facilitará toda la información indicada a continuación:

- a) la identidad y los datos de contacto del responsable y, en su caso, de su representante;*
- b) los datos de contacto del delegado de protección de datos, en su caso;*
- c) los fines del tratamiento a que se destinan los datos personales y la base jurídica del tratamiento;*
- d) cuando el tratamiento se base en el artículo 6, apartado 1, letra f), los intereses legítimos del responsable o de un tercero;*
- e) los destinatarios o las categorías de destinatarios de los datos personales, en su caso;*
- f) en su caso, la intención del responsable de transferir datos personales a un tercer país u organización internacional y la existencia o ausencia de una decisión de adecuación de la Comisión, o, en el caso de las transferencias indicadas en los artículos 46 o 47 o el artículo 49, apartado 1, párrafo segundo, referencia a las garantías adecuadas o apropiadas y a los medios para obtener una copia de estas o al lugar en que se hayan puesto a disposición.*

2. Además de la información mencionada en el apartado 1, el responsable del tratamiento facilitará al interesado, en el momento en que se obtengan los datos personales, la siguiente información necesaria para garantizar un tratamiento de datos leal y transparente:

- a) el plazo durante el cual se conservarán los datos personales o, cuando no sea*

posible, los criterios utilizados para determinar este plazo;

b) la existencia del derecho a solicitar al responsable del tratamiento el acceso a los datos personales relativos al interesado, y su rectificación o supresión, o la limitación de su tratamiento, o a oponerse al tratamiento, así como el derecho a la portabilidad de los datos;

c) cuando el tratamiento esté basado en el artículo 6, apartado 1, letra a), o el artículo 9, apartado 2, letra a), la existencia del derecho a retirar el consentimiento en cualquier momento, sin que ello afecte a la licitud del tratamiento basado en el consentimiento previo a su retirada;

d) el derecho a presentar una reclamación ante una autoridad de control;

e) si la comunicación de datos personales es un requisito legal o contractual, o un requisito necesario para suscribir un contrato, y si el interesado está obligado a facilitar los datos personales y está informado de las posibles consecuencias de no facilitar tales datos;

f) la existencia de decisiones automatizadas, incluida la elaboración de perfiles, a que se refiere el artículo 22, apartados 1 y 4, y, al menos en tales casos, información significativa sobre la lógica aplicada, así como la importancia y las consecuencias previstas de dicho tratamiento para el interesado.

3. Cuando el responsable del tratamiento proyecte el tratamiento ulterior de datos personales para un fin que no sea aquel para el que se recogieron, proporcionará al interesado, con anterioridad a dicho tratamiento ulterior, información sobre ese otro fin y cualquier información adicional pertinente a tenor del apartado 2.

4. Las disposiciones de los apartados 1, 2 y 3 no serán aplicables cuando y en la medida en que el interesado ya disponga de la información."

De acuerdo con estas normas, la obligación de informar corresponde al responsable del tratamiento de los datos personales y debe suministrarse por adelantado (Considerando 39 del RGPD).

En este caso, **A.A.A.** manifestó a los servicios de inspección no haber facilitado información a sus clientes sobre los tratamientos de datos objeto de las presentes actuaciones. Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a **A.A.A.** por vulneración de lo establecido en el artículo 13 del RGPD.

VI

Tipificación de la infracción del artículo 13 del RGPD y calificación a efectos de prescripción

Existen, por tanto, evidencias de un posible incumplimiento de lo establecido en el artículo 13 del RGPD, que supone la comisión de una infracción tipificada en el artículo 83.5.b) del mismo Reglamento, que bajo la rúbrica "*Condiciones generales para la imposición de multas administrativas*" dispone lo siguiente:

"Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del

volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía: a) (...)

b) los derechos de los interesados a tenor de los artículos 12 a 22;" (...)".

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".

A los solos efectos del plazo de prescripción, el artículo 72.1.h) de la LOPDGDD establece lo siguiente:

"1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

h) La omisión del deber de informar al afectado acerca del tratamiento de sus datos personales conforme a lo dispuesto en los artículos 13 y 14 del Reglamento (UE) 2016/679 y 12 de esta Ley Orgánica".

VII

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

"1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias."

"2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;

f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;

- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción."*

Dentro de este apartado, la LOPDGDD contempla en su artículo 76, titulado "Sanciones y medidas correctivas":

"1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.*

3. Será posible, complementaria o alternativamente, la adopción, cuando proceda, de las restantes medidas correctivas a las que se refiere el artículo 83.2 del Reglamento (UE) 2016/679."

En el presente caso, considerando la gravedad de la posible infracción, atendiendo especialmente a las consecuencias que su comisión provoca en los afectados, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, la condición de empresario individual de **A.A.A.**

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

. Artículo 83.2.a) del RGPD: *“a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido”.*

. La naturaleza de la infracción: los hechos puestos de manifiesto afectan a un principio básico relativo al tratamiento de los datos de carácter personal, como es el de transparencia, que la norma sanciona con la mayor gravedad, al tratar datos de los clientes de **A.A.A.** sin haber sido convenientemente informados sobre dicho tratamiento.

. Gravedad de la infracción, teniendo en cuenta el número de registros que constan en los archivos creados por **A.A.A.**, así como el número de interesados cuyos datos personales constan anotados en dichos ficheros, según los detalles que constan reseñados en los antecedentes del presente acto.

. Duración de la infracción: consta en las actuaciones tratamientos de datos personales realizados durante el período comprendido entre 2018 y 2024, según los detalles reseñados en los antecedentes del presente acto.

. Artículo 83.2.g) del RGPD: *“Las categorías de los datos de carácter personal afectados por la infracción”*: la infracción se pone de manifiesto respecto de datos personales relativos a la salud de los interesados.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD, con respecto a la presunta infracción por vulneración de lo establecido en el artículo 13 del RGPD, permite fijar inicialmente una sanción de multa administrativa por importe de 3.000,00 euros.

VIII

Obligación incumplida: infracción del artículo 9 “Tratamiento de categorías especiales de datos personales”

Según ha quedado expuesto, en el caso presente nos encontramos ante tratamientos de datos personales relativos a la salud, incluidos en las categorías especiales de datos personales reguladas en el artículo 9.1 RGPD, a las que resulta aplicable el principio de prohibición de tratamiento, salvo que concurra alguna de las circunstancias previstas en el apartado 2 de dicho artículo.

Este artículo 9 del RGPD, que regula el tratamiento de categorías especiales de datos personales, establece lo siguiente:

“1. Quedan prohibidos el tratamiento de datos personales que revelen el origen étnico o racial, las opiniones políticas, las convicciones religiosas o filosóficas, o la afiliación sindical, y el tratamiento de datos genéticos, datos biométricos dirigidos a identificar

de manera unívoca a una persona física, datos relativos a la salud o datos relativos a la vida sexual o la orientación sexual de una persona física.

2. El apartado 1 no será de aplicación cuando concorra una de las circunstancias siguientes:

a) el interesado dio su consentimiento explícito para el tratamiento de dichos datos personales con uno o más de los fines especificados, excepto cuando el Derecho de la Unión o de los Estados miembros establezca que la prohibición mencionada en el apartado 1 no puede ser levantada por el interesado;

b) el tratamiento es necesario para el cumplimiento de obligaciones y el ejercicio de derechos específicos del responsable del tratamiento o del interesado en el ámbito del Derecho laboral y de la seguridad y protección social, en la medida en que así lo autorice el Derecho de la Unión o de los Estados miembros o un convenio colectivo con arreglo al Derecho de los Estados miembros que establezca garantías adecuadas del respeto de los derechos fundamentales y de los intereses del interesado;

c) el tratamiento es necesario para proteger intereses vitales del interesado o de otra persona física, en el supuesto de que el interesado no esté capacitado, física o jurídicamente, para dar su consentimiento;

d) el tratamiento es efectuado, en el ámbito de sus actividades legítimas y con las debidas garantías, por una fundación, una asociación o cualquier otro organismo sin ánimo de lucro, cuya finalidad sea política, filosófica, religiosa o sindical, siempre que el tratamiento se refiera exclusivamente a los miembros actuales o antiguos de tales organismos o a personas que mantengan contactos regulares con ellos en relación con sus fines y siempre que los datos personales no se comuniquen fuera de ellos sin el consentimiento de los interesados;

e) el tratamiento se refiere a datos personales que el interesado ha hecho manifiestamente públicos;

f) el tratamiento es necesario para la formulación, el ejercicio o la defensa de reclamaciones o cuando los tribunales actúen en ejercicio de su función judicial;

g) el tratamiento es necesario por razones de un interés público esencial, sobre la base del Derecho de la Unión o de los Estados miembros, que debe ser proporcional al objetivo perseguido, respetar en lo esencial el derecho a la protección de datos y establecer medidas adecuadas y específicas para proteger los intereses y derechos fundamentales del interesado;

h) el tratamiento es necesario para fines de medicina preventiva o laboral, evaluación de la capacidad laboral del trabajador, diagnóstico médico, prestación de asistencia o tratamiento de tipo sanitario o social, o gestión de los sistemas y servicios de asistencia sanitaria y social, sobre la base del Derecho de la Unión o de los Estados miembros o en virtud de un contrato con un profesional sanitario y sin perjuicio de las condiciones y garantías contempladas en el apartado 3;

i) el tratamiento es necesario por razones de interés público en el ámbito de la salud pública, como la protección frente a amenazas transfronterizas graves para la salud, o

para garantizar elevados niveles de calidad y de seguridad de la asistencia sanitaria y de los medicamentos o productos sanitarios, sobre la base del Derecho de la Unión o de los Estados miembros que establezca medidas adecuadas y específicas para proteger los derechos y libertades del interesado, en particular el secreto profesional;

j) el tratamiento es necesario con fines de archivo en interés público, fines de investigación científica o histórica o fines estadísticos, de conformidad con el artículo 89, apartado 1, sobre la base del Derecho de la Unión o de los Estados miembros, que debe ser proporcional al objetivo perseguido, respetar en lo esencial el derecho a la protección de datos y establecer medidas adecuadas y específicas para proteger los intereses y derechos fundamentales del interesado.

3. Los datos personales a que se refiere el apartado 1 podrán tratarse a los fines citados en el apartado 2, letra h), cuando su tratamiento sea realizado por un profesional sujeto a la obligación de secreto profesional, o bajo su responsabilidad, de acuerdo con el Derecho de la Unión o de los Estados miembros o con las normas establecidas por los organismos nacionales competentes, o por cualquier otra persona sujeta también a la obligación de secreto de acuerdo con el Derecho de la Unión o de los Estados miembros o de las normas establecidas por los organismos nacionales competentes.

4. Los Estados miembros podrán mantener o introducir condiciones adicionales, inclusive limitaciones, con respecto al tratamiento de datos genéticos, datos biométricos o datos relativos a la salud."

En el presente caso, **A.A.A.** lleva a cabo tratamientos de datos personales de sus clientes que incluyen códigos de identificación asignados por los sistemas públicos sanitarios, tratamientos médicos o incidencias relacionadas con dichos tratamientos, entre otros como la identidad del médico y centro de salud que prestan la atención sanitaria primaria al interesado; sin que el responsable haya acreditado la concurrencia de alguna de las circunstancias que permite levantar la prohibición del tratamiento de esta categoría especial de datos personales establecida en el apartado 1 del artículo 9 del RGPD citado.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a **A.A.A.**, por vulneración del artículo transcrito anteriormente.

IX

Tipificación de la infracción del artículo 9 del RGPD y calificación a efectos de prescripción

El artículo 83.5 del RGPD tipifica como infracción administrativa la vulneración del artículo siguiente, que se sancionará, de acuerdo con el apartado 2, con multas administrativas de 20.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

"a) los principios básicos para el tratamiento, incluidas las condiciones para el

consentimiento a tenor de los artículos 5, 6, 7 y 9;"

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".

A los solos efectos del plazo de prescripción, el artículo 72.1 de la LOPDGDD establece lo siguiente:

"En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

e) El tratamiento de datos personales de las categorías a las que se refiere el artículo 9 del Reglamento (UE) 2016/679, sin que concorra alguna de las circunstancias previstas en dicho precepto y en el artículo 9 de esta ley orgánica."

X

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, ya transcritos en el Fundamento de Derecho VII.

En el presente caso, considerando la gravedad de la posible infracción, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Como se ha indicado anteriormente, se considera, con carácter previo, la condición de empresario individual de **A.A.A.**

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

. Artículo 83.2.a) del RGPD: *"a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido".*

. La naturaleza de la infracción: los hechos puestos de manifiesto están relacionados con una de las prohibiciones básicas reguladas en el RGPD que la norma sanciona con la mayor gravedad.

. Gravedad de la infracción, teniendo en cuenta el número de registros que constan en los archivos creados por **A.A.A.**, así como el número de interesados cuyos datos personales constan anotados en dichos ficheros, según los detalles que constan reseñados en los antecedentes del presente acto.

. Duración de la infracción: consta en las actuaciones tratamientos de datos personales realizados durante el período comprendido entre 2018 y 2024, según los detalles reseñados en los antecedentes del presente acto.

. Artículo 76.2.b) de la LOPDGDD: *“La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”*:

La parte reclamada presta servicios farmacéuticos, por lo que en el desarrollo de la actividad que le es propia necesita de manera habitual tratar datos de carácter personal relativos a la salud, lo que incide en la diligencia que le es exigible para el cumplimiento de los principios que presiden el tratamiento de datos de carácter personal.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD, con respecto a la presunta infracción por vulneración de lo establecido en el artículo 9 del RGPD, permite fijar inicialmente una sanción de multa administrativa por importe de 10.000,00 euros.

XI

Obligación incumplida. Seguridad del tratamiento

El artículo 32 del RGPD estipula lo siguiente:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros."

El artículo 32 no establece medidas de seguridad estáticas, sino que corresponderá a responsables y encargados determinar aquellas medidas de seguridad que son necesarias para garantizar la confidencialidad, la integridad y la disponibilidad de los datos personales, por lo tanto, un mismo tratamiento de datos puede implicar medidas de seguridad distintas en función de las especificidades concretas en las que tiene lugar dicho tratamiento de datos.

En consonancia con estas previsiones, el Considerando 75 del RGPD establece:

"(75) Los riesgos para los derechos y libertades de las personas físicas, de gravedad y probabilidad variables, pueden deberse al tratamiento de datos que pudieran provocar daños y perjuicios físicos, materiales o inmateriales, en particular en los casos en los que el tratamiento pueda dar lugar a problemas de discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, reversión no autorizada de la seudonimización o cualquier otro perjuicio económico o social significativo; en los casos en los que se prive a los interesados de sus derechos y libertades o se les impida ejercer el control sobre sus datos personales; en los casos en los que los datos personales tratados revelen el origen étnico o racial, las opiniones políticas, la religión o creencias filosóficas, la militancia en sindicatos y el tratamiento de datos genéticos, datos relativos a la salud o datos sobre la vida sexual, o las condenas e infracciones penales o medidas de seguridad conexas; en los casos en los que se evalúen aspectos personales, en particular el análisis o la predicción de aspectos referidos al rendimiento en el trabajo, situación económica, salud, preferencias o intereses personales, fiabilidad o comportamiento, situación o movimientos, con el fin de crear o utilizar perfiles personales; en los casos en los que se traten datos personales de personas vulnerables, en particular niños; o en los casos en los que el tratamiento implique una gran cantidad de datos personales y afecte a un gran número de interesados".

Asimismo, el Considerando 83 del RGPD establece:

"(83) A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales".

En definitiva, el primer paso para determinar las medidas de seguridad será la evaluación del riesgo. Una vez evaluado será necesario determinar las medidas de seguridad encaminadas para reducir o eliminar los riesgos para el tratamiento de los datos.

La seguridad de los datos requiere la aplicación de medidas técnicas u organizativas apropiadas al tratamiento de los datos personales para proteger dichos datos contra el acceso, uso, modificación, difusión, pérdida, destrucción o daño accidental, no autorizado o ilícito. En este sentido, las medidas de seguridad son claves a la hora de garantizar el derecho fundamental a la protección de datos. No es posible la existencia del derecho fundamental a la protección de datos personales si no es posible garantizar la confidencialidad, la integridad y la disponibilidad de estos.

No debe olvidarse que, de conformidad con el artículo 32.1 del RGPD citado, las medidas técnicas y organizativas a aplicar para garantizar un nivel de seguridad adecuado al riesgo deben tener en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas.

Derivado de la actividad a la que se dedica, **A.A.A.** está obligado a realizar de forma muy especializada un análisis de los riesgos y una implantación de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo de su actividad para los derechos y libertades de las personas.

Por tanto, a la hora de evaluar los riesgos y determinar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo para los derechos y libertades de las personas físicas de los tratamientos de datos que realiza, está obligada a tener en cuenta la concreta actividad que supone su negocio, que conlleva tratar datos personales relativos a la salud de forma continua. Así, los riesgos derivados de su actividad deben atenderse de forma especializada.

En el presente caso, en relación con los ficheros que constituyen el objeto de las presentes actuaciones, existen indicios que llevan a considerar que **A.A.A.** no cuenta con las medidas de seguridad apropiadas para garantizar un nivel de seguridad adecuado al riesgo de sus tratamientos de datos personales, con la consiguiente falta de diligencia, en tanto que responsable, a la hora de evitar el acceso no autorizado por terceros ajenos.

Prueba de que los sistemas de información de la parte reclamada no cuentan con las medidas adecuadas, ni siquiera las básicas para garantizar la confidencialidad, integridad y disponibilidad de los datos personales, son las propias manifestaciones realizadas por **A.A.A.** a los Servicios de Inspección de esta AEPD cuando reconoce que los repetidos archivos se encuentran alojados en el “escritorio” de los ordenadores empleados en la oficina de farmacia y estos ubicados en los mostradores de venta al público, permitiendo a los clientes *“acceso visual en todo momento a la pantalla del ordenador”*; que ha previsto la realización copias de seguridad, o que el acceso se produce solo con la contraseña que protege el ordenador, la cual es única y conocida por todas las personas que trabajan en la oficina de farmacia.

Por tanto, de conformidad con las evidencias de las que se dispone en este momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a **A.A.A.**, por vulneración del artículo 32 del RGPD.

XII

Tipificación de la infracción del artículo 32 del RGPD y calificación a efectos de prescripción

El artículo 83.4 del RGPD tipifica como infracción administrativa la vulneración del artículo siguiente, que se sancionará, de acuerdo con el apartado 2, con multas administrativas de 10.000.000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

"a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;"

Por su parte, la LOPDGDD en su artículo 71, Infracciones, señala que:

"Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica".

A los solos efectos del plazo de prescripción, el artículo 73 de la LOPDGDD establece lo siguiente:

"En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679."

XIII

Propuesta de sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, que constan reproducidos en el Fundamento de Derecho VII.

En el presente caso, considerando la gravedad de la posible infracción, correspondería la imposición de multa, además de la adopción de medidas, si procede.

La multa que se imponga deberá ser, en cada caso individual, efectiva, proporcionada y disuasoria, conforme a lo establecido en el artículo 83.1 del RGPD. Para garantizar estos principios, se considera, con carácter previo, la condición de empresario individual de **A.A.A.**

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, y sin perjuicio de lo que resulte de la instrucción, se considera que procede graduar la sanción a imponer de acuerdo con

las circunstancias siguientes, contempladas en los preceptos antes citados.

Con carácter previo, se estima que concurren las circunstancias siguientes:

. Artículo 83.2.a) del RGPD: *“a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido”.*

. Gravedad de la infracción, teniendo en cuenta el número de registros que constan en los archivos creados por **A.A.A.**, así como el número de interesados cuyos datos personales constan anotados en dichos ficheros, según los detalles que constan reseñados en los antecedentes del presente acto.

. Duración de la infracción: consta en las actuaciones tratamientos de datos personales realizados durante el período comprendido entre 2018 y 2024, según los detalles reseñados en los antecedentes del presente acto.

. Artículo 83.2.b) del RGPD: *“La intencionalidad o negligencia en la infracción”.*

Considerando los riesgos para la privacidad que conlleva el tratamiento de datos personales relativos a la salud y tratándose de un responsable titular de una oficina de farmacia, en este caso estamos ante una acción negligente grave.

En este sentido resulta muy ilustrativa la SAN de 17 de octubre de 2007(rec. 63/2006), la cual indica que *“...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las prevenciones legales al respecto”*

. Artículo 83.2.g) del RGPD: *“Las categorías de los datos de carácter personal afectados por la infracción”*: la infracción se pone de manifiesto respecto de datos personales relativos a la salud de los interesados.

. Artículo 76.2.b) de la LOPDGDD: *“La vinculación de la actividad del infractor con la realización de tratamientos de datos personales”*:

La parte reclamada presta servicios farmacéuticos, por lo que en el desarrollo de la actividad que le es propia necesita de manera habitual tratar datos de carácter personal relativos a la salud.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD, con respecto a la presunta infracción por vulneración de lo establecido en el artículo 13 del RGPD, permite fijar inicialmente una sanción de multa administrativa por importe de 3.000,00 euros.

XIV Medidas correctivas

De confirmarse las infracciones, la resolución que se dicte podrá establecer las medidas correctivas que la entidad infractora deberá adoptar para poner fin al incumplimiento de la legislación de protección de datos personales, en este caso de los artículos 13, 9 y 32 del RGPD, de acuerdo con lo establecido en el citado artículo 58.2.d) del RGPD, según el cual cada autoridad de control podrá *“ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado;”*.

Así, se podrá requerir a la entidad responsable para que adecúe su actuación a la normativa de protección de datos personales, con el alcance expresado en los anteriores Fundamentos de Derecho.

En el presente acto se establece cuál es la presunta infracción cometida y los hechos que podrían dar lugar a esa posible vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

No obstante, en este caso, con independencia de lo anterior, de conformidad con las evidencias de que se dispone en el presente momento de acuerdo de inicio de procedimiento sancionador, en la resolución que se adopte se podrá requerir a **A.A.A.** para que, en el plazo de dos meses, a contar desde la fecha de ejecutividad de la resolución finalizadora de este procedimiento, adopte las medidas siguientes:

. Eliminar los ficheros “Excel” objeto de las presentes actuaciones. De no ser posible porque pudiera verse afectada la asistencia al paciente y titular de los datos personales registrados en dichos ficheros o cualquier otra circunstancia que justifique debidamente su conservación, deberá adoptar las medidas necesarias para asegurar la información, evitando que sea accedida indebidamente por terceros o personal no habilitado. De continuar el tratamiento, **A.A.A.** deberá ajustar su actuación a lo dispuesto en los artículos 13, 9 y 32 del RGPD, con el alcance expresado en el presente acto.

La imposición de estas medidas es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

Se advierte que no atender la posible orden de adopción de medidas impuestas por este organismo en la resolución del presente procedimiento sancionador podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Asimismo, se recuerda que ni el reconocimiento de la infracción cometida ni, en su caso, el pago voluntario de las cuantías propuestas, eximen de la obligación de adoptar las medidas pertinentes para que cese la conducta o se corrijan los efectos de la infracción cometida y la de acreditar ante esta AEPD el cumplimiento de esa

obligación.

Por lo tanto, a tenor de lo anteriormente expuesto, por la Presidencia de la Agencia Española de Protección de Datos,
SE ACUERDA:

PRIMERO: INICIAR PROCEDIMIENTO SANCIONADOR a **A.A.A.**, con NIF *****NIF.1**,

- por la presunta infracción del artículo 13 del RGPD, tipificada en el artículo 83.5.b) del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1.h) de la LOPDGDD.
- por la presunta infracción del artículo 9 del RGPD, tipificada en el artículo 83.5.a) del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1.e) de la LOPDGDD.
- por la presunta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 del RGPD, calificada como grave a efectos de prescripción, en el artículo 73 f) de la LOPDGDD.

SEGUNDO: NOMBRAR como instructora a **B.B.B.** y, como secretaria a **C.C.C.** indicando que podrán ser recusados, en su caso, conforme a lo establecido en los artículos 23 y 24 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (LRJSP).

TERCERO: INCORPORAR al expediente, a efectos probatorios, así como los documentos obtenidos y generados por la Subdirección General de Inspección de Datos en las actuaciones previas al inicio del presente procedimiento sancionador.

CUARTO: QUE a los efectos previstos en el art. 64.2 b) de la ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, la sanción que pudiera corresponder sería de multa administrativa de 16.000 euros (dieciséis mil euros), sin perjuicio de lo que resulte de la instrucción.

- Por la supuesta infracción del artículo 13 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía: 3.000,00 euros.
- Por la supuesta infracción del artículo 9 del RGPD, tipificada en el artículo 83.5 de dicha norma, multa administrativa de cuantía: 10.000,00 euros.
- Por la supuesta infracción del artículo 32 del RGPD, tipificada en el artículo 83.4 de dicha norma, multa administrativa de cuantía: 3.000,00 euros.

Asimismo, la infracción imputada, de confirmarse, podrá conllevar la imposición de medidas, de acuerdo con lo establecido en el citado artículo 64.3 de la LOPDGDD.

QUINTO: NOTIFICAR el presente acuerdo a **A.A.A.**, con NIF *****NIF.1**, otorgándole un plazo de audiencia de diez días hábiles para que formule las alegaciones y presente las pruebas que considere convenientes. En su escrito de alegaciones deberá facilitar su NIF y el número de procedimiento que figura en el encabezamiento de este documento.

De conformidad con lo dispuesto en el artículo 85 de la LPACAP, podrá reconocer su

responsabilidad dentro del plazo otorgado para la formulación de alegaciones al presente acuerdo de inicio; lo que llevará aparejada una reducción de un 20% de la sanción que proceda imponer en el presente procedimiento. Con la aplicación de esta reducción, la sanción quedaría establecida en 12.800 euros (doce mil ochocientos euros), resolviéndose el procedimiento con la imposición de esta sanción.

Del mismo modo podrá, en cualquier momento anterior a la resolución del presente procedimiento, llevar a cabo el pago voluntario de la sanción propuesta, lo que supondrá la reducción de un 20% de su importe. Con la aplicación de esta reducción, la sanción quedaría establecida en 12.800 euros (doce mil ochocientos euros) y su pago implicará la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

La reducción por el pago voluntario de la sanción es acumulable a la que corresponde aplicar por el reconocimiento de la responsabilidad, siempre que este reconocimiento de la responsabilidad se ponga de manifiesto dentro del plazo concedido para formular alegaciones a la apertura del procedimiento. El pago voluntario de la cantidad referida en el párrafo anterior podrá hacerse en cualquier momento anterior a la resolución. En este caso, si procediera aplicar ambas reducciones, el importe de la sanción quedaría establecido en 9.600 euros (nueve mil seiscientos euros).

En todo caso, la efectividad de cualquiera de las dos reducciones mencionadas estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

En caso de que optara por proceder al pago voluntario de cualquiera de las cantidades señaladas anteriormente (12.800 o 9.600 euros), deberá hacerlo efectivo mediante su ingreso en la cuenta nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)** abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A., indicando en el concepto el número de referencia del procedimiento que figura en el encabezamiento de este documento y la causa de reducción del importe a la que se acoge.

Asimismo, deberá enviar el justificante del ingreso a la Subdirección General de Inspección junto con la comunicación expresa del desistimiento o renuncia a cualquier acción o recurso en vía administrativa contra la sanción para continuar con el procedimiento en concordancia con la cantidad ingresada.

Por último, se señala que conforme a lo establecido en el artículo 112.1 de la LPACAP, contra el presente acto no cabe recurso administrativo alguno.

1479-200325

Lorenzo Cotino Hueso
Presidente de la Agencia Española de Protección de Datos

>>

SEGUNDO: En fecha 10 de abril de 2025, **A.A.A.** ha procedido al pago de la sanción en la cuantía de **9.600,00 euros** haciendo uso de las dos reducciones previstas en el acuerdo de inicio transcrito anteriormente, lo que implica el reconocimiento de la

responsabilidad en relación con los hechos a los que se refiere el acuerdo de inicio y su calificación jurídica.

TERCERO: En el acuerdo de inicio transcrito anteriormente se señalaba que, de confirmarse la infracción, podría acordarse imponer al responsable la adopción de medidas adecuadas para ajustar su actuación a la normativa mencionada en este acto, de acuerdo con lo establecido en el citado artículo 58.2 d) del RGPD, según el cual cada autoridad de control podrá *“ordenar al responsable o encargado del tratamiento que las operaciones de tratamiento se ajusten a las disposiciones del presente Reglamento, cuando proceda, de una determinada manera y dentro de un plazo especificado...”*.

Habiéndose reconocido la responsabilidad de la infracción, procede la imposición de las medidas incluidas en el acuerdo de inicio.

FUNDAMENTOS DE DERECHO

I

Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos.”*

II

Terminación del procedimiento

El artículo 85 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en lo sucesivo, LPACAP), bajo la rúbrica *“Terminación en los procedimientos sancionadores”* dispone lo siguiente:

“1. Iniciado un procedimiento sancionador, si el infractor reconoce su responsabilidad, se podrá resolver el procedimiento con la imposición de la sanción que proceda.

2. Cuando la sanción tenga únicamente carácter pecuniario o bien quepa imponer una sanción pecuniaria y otra de carácter no pecuniario pero se ha justificado la improcedencia de la segunda, el pago voluntario por el presunto responsable, en cualquier momento anterior a la resolución, implicará la terminación del procedimiento,

salvo en lo relativo a la reposición de la situación alterada o a la determinación de la indemnización por los daños y perjuicios causados por la comisión de la infracción.

3. En ambos casos, cuando la sanción tenga únicamente carácter pecuniario, el órgano competente para resolver el procedimiento aplicará reducciones de, al menos, el 20 % sobre el importe de la sanción propuesta, siendo éstos acumulables entre sí. Las citadas reducciones, deberán estar determinadas en la notificación de iniciación del procedimiento y su efectividad estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

El porcentaje de reducción previsto en este apartado podrá ser incrementado reglamentariamente.”

III

Pago voluntario y reconocimiento de responsabilidad

De conformidad con lo dispuesto en el citado artículo 85 de la LPACAP, en el acuerdo de inicio notificado se informaba sobre la posibilidad de reconocer la responsabilidad y de realizar el pago voluntario de la sanción propuesta, lo que supondría dos reducciones acumulables de un 20% cada una. Con la aplicación de estas dos reducciones, la sanción quedaría establecida en **9.600,00 euros** y su pago implicaría la terminación del procedimiento, sin perjuicio de la imposición de las medidas correspondientes.

Tras la notificación del citado acuerdo de inicio, **A.A.A.** ha procedido al reconocimiento de la responsabilidad y al pago voluntario de la sanción, acogiéndose a las dos reducciones previstas. De conformidad con el apartado 3 del artículo 85 LPACAP, la efectividad de las citadas reducciones estará condicionada al desistimiento o renuncia de cualquier acción o recurso en vía administrativa contra la sanción.

Debe tenerse en cuenta que, de acuerdo con los preceptos de la LPACAP, así como de la jurisprudencia del Tribunal Supremo en esta materia, el ejercicio del pago voluntario por el presunto responsable no exime a la administración de la obligación de resolver y notificar todos los procedimientos, cualquiera que sea su forma de iniciación. De igual forma, el artículo 88 de la citada norma establece que la resolución que ponga fin al procedimiento decidirá todas las cuestiones planteadas por los interesados y aquellas otras derivadas del mismo.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones, la Presidencia de la Agencia Española de Protección de Datos **RESUELVE:**

PRIMERO: DECLARAR la comisión de las infracciones y CONFIRMAR las sanciones determinadas en la parte dispositiva del acuerdo de inicio transcrito en la presente resolución.

La suma de las citadas cuantías arroja una cantidad total **16.000,00 euros**.

Tras haber procedido **A.A.A.** al pronto pago y reconocimiento de responsabilidad, se procede, en virtud del artículo 85 de la LPACAP, a la reducción de un 40% del total mencionado, lo cual supone la cantidad definitiva de **9.600,00 euros**.

La efectividad de las citadas reducciones está condicionada, en todo caso, al desistimiento o renuncia de cualquier acción o recurso en vía administrativa.

SEGUNDO: DECLARAR la terminación del procedimiento **EXP202313747**, de conformidad con lo establecido en el artículo 85 de la LPACAP.

TERCERO: ORDENAR a **A.A.A.** para que en el plazo de 2 meses desde que la presente resolución sea firme y ejecutiva, notifique a la Agencia la adopción de las medidas que se describen en los fundamentos de derecho del acuerdo de inicio transcrito en la presente resolución.

CUARTO: NOTIFICAR la presente resolución a **A.A.A.**.

QUINTO: De acuerdo con lo previsto en el artículo 85 de la LPACAP que condiciona la reducción por pago voluntario y reconocimiento de la responsabilidad al desistimiento o renuncia de cualquier acción o recurso en vía administrativa, la presente resolución será firme en vía administrativa y plenamente ejecutiva a partir de su notificación.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa según lo preceptuado por el art. 114.1.c) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas, los interesados podrán interponer recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-Administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

No obstante, conforme a lo previsto en el artículo 90.3.a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sede.aepd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.



Presidente de la Agencia Española de Protección de Datos